



ICT306 Advanced Cybersecurity

WEEK 9 Privacy, Anonymity, and Censorship

Exploring VPN technologies, web tracking mechanisms, anonymity tools, and the evolving landscape of digital privacy — from IPSec to Tor.

MODULE OVERVIEW

Remote Access

- **Remote access** is the ability for an authorized user to connect to a private network or system from an external location — typically over the public Internet.
- As organizations become increasingly distributed, **securing remote access has become a critical challenge in modern cybersecurity**.
- This lecture explores the technologies and protocols that make secure remote access possible, starting with Virtual Private Networks (VPNs).



Virtual Private Networks (VPNs)

📄 **Core Problem:** How do you provide secure communication for non-TLS protocols across the public Internet?

- **VPNs** solve this by creating a **virtual shared network** over the public Internet in which **all traffic is encrypted end-to-end**.
- They effectively tunnel private traffic through an untrusted medium, making it appear as if all endpoints share a common secure network.

Remote Client VPN

A traveling employee (e.g., with a laptop) connects securely back to the corporate network from any Internet-connected location.

Site-to-Site VPN

Two geographically separate networks (e.g., branch offices) are connected across the Internet as if they were on the same local network.

IPSec

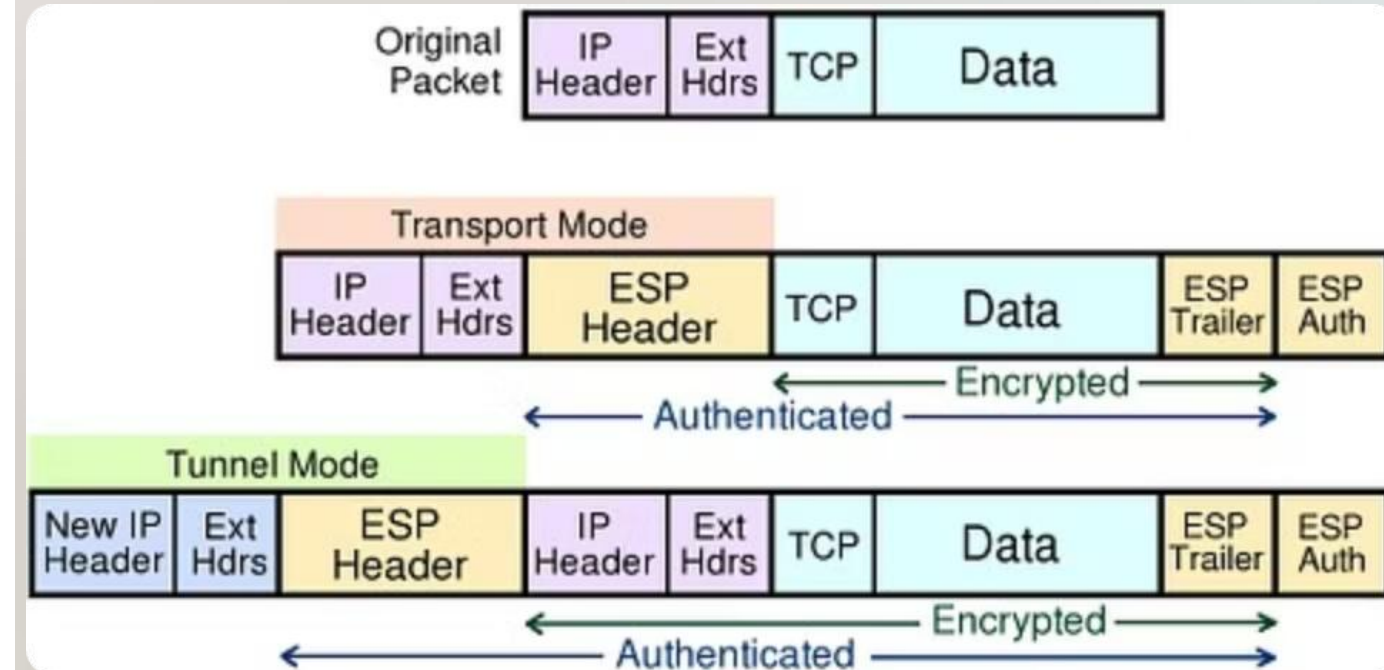
- Several VPN protocols exist — including **PPTP (Point-to-Point Tunneling Protocol)**, **L2TP (Layer 2 Tunneling Protocol)**, **IPSec**, and **OpenVPN**.
- The most widely deployed is **IPSec**, which operates at the network layer and secures IP communications by authenticating and encrypting each IP packet.
- **OpenVPN** is a popular open-source alternative.
- **IPSec** supports two key operational modes:

Transport Mode

- Only the **payload of the IP packet is encrypted** and authenticated.
- The original IP header is preserved.
- Used for end-to-end communication between two hosts.

Tunnel Mode

- The **entire original IP packet is encapsulated and encrypted** inside a new IP packet with a new header.
- Used for gateway-to-gateway (site-to-site) VPNs.



WireGuard

- WireGuard is a modern VPN protocol introduced in the late 2010s that has rapidly gained a significant following over legacy options like OpenVPN and IPSec.
- Its design philosophy prioritizes simplicity, speed, and strong cryptographic foundations.

Simplicity & Performance

- WireGuard's codebase is **dramatically smaller than OpenVPN's** (~4,000 lines vs. ~70,000+), making it far easier to audit.
- Fewer configuration options reduce the attack surface and the chance of misconfiguration.

Modern Cryptographic Primitives

Built on the **Noise Protocol Framework**, WireGuard uses **Curve25519** for key exchange, **ChaCha20** for symmetric encryption, and **Poly1305** for message authentication — ***all considered best-in-class.***

Kernel-Level Integration

WireGuard **operates inside the OS kernel** (Linux, Windows, macOS), enabling high throughput and low latency that surpasses software-layer VPNs like OpenVPN.

Cisco AnyConnect

- Stanford University and many major organizations deploy **Cisco AnyConnect** as [their enterprise VPN solution](#).
- What makes it architecturally distinctive is its use of **TLS as the encapsulation protocol** — the same protocol securing web traffic — making it highly firewall-friendly.

1

Initial Handshake

Standard TCP-based TLS (port 443) is used to authenticate the client and establish the session — indistinguishable from HTTPS traffic.

2

Data Transport

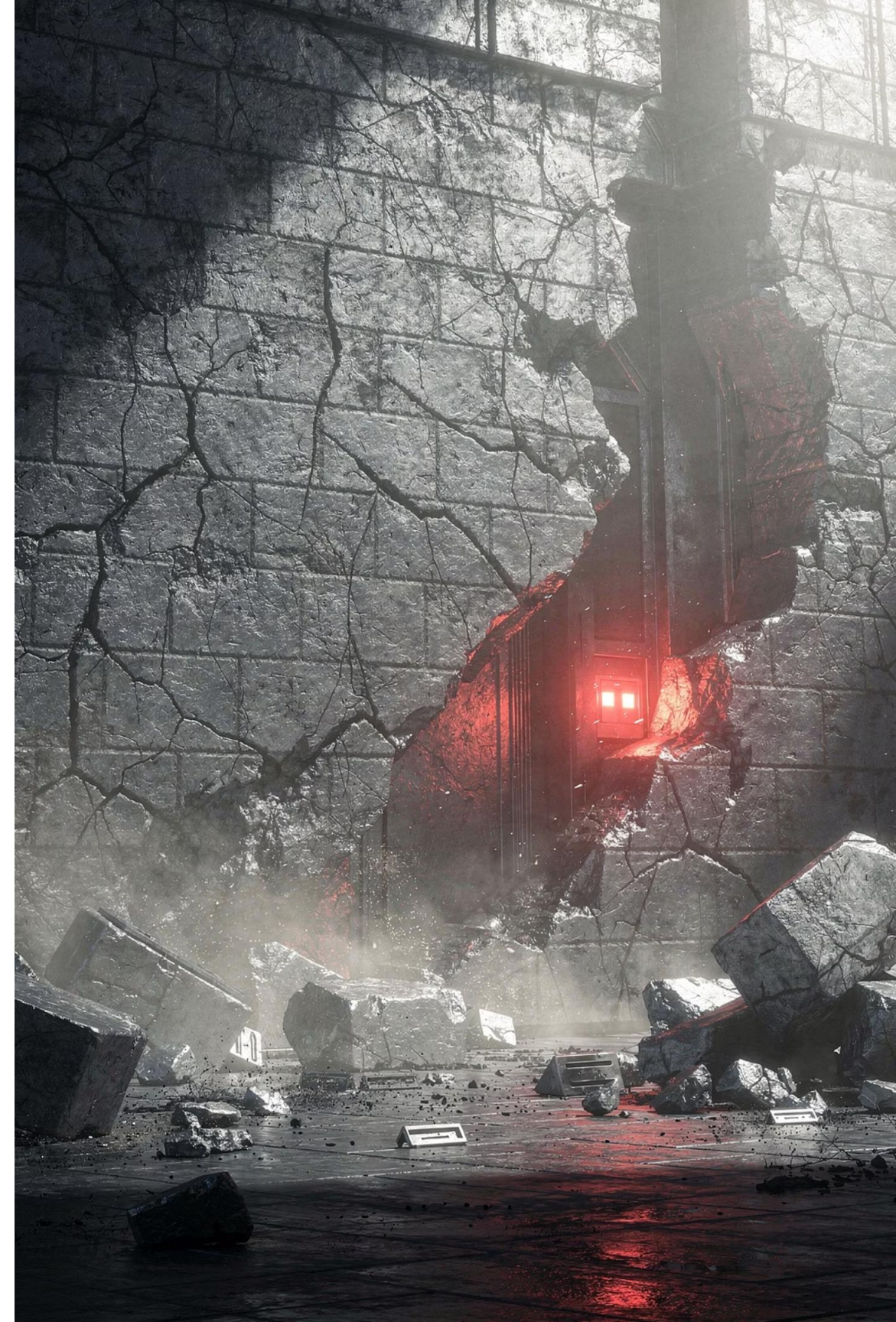
After the handshake, AnyConnect [switches](#) to **DTLS** (Datagram TLS over UDP) for high-performance data transport with lower latency.



The "Goosey Middle" Problem

❏ **Core Assumption:** *VPNs are built on the premise that the internal network is trusted, and the public Internet is not.*

- This perimeter-based security model works in theory **but breaks down in practice.**
- **Once an attacker breaches the network boundary** — through a phishing attack, compromised credential, or insider threat — they gain largely **unrestricted lateral movement** inside the internal network.
- **Computers are compromised regularly**, and an attacker with internal access has free rein to explore, escalate privileges, and exfiltrate data.
- **The internal network isn't nearly as secure as the model assumes.**



Zero Trust Security (BeyondCorp)

- Google's **BeyondCorp** initiative [challenged the traditional perimeter model by assuming the internal network is *also* hostile](#).
- Rather than trusting a network location, access decisions are made entirely based on **device identity and user credentials** — verified continuously, regardless of whether the user is on-premises or remote.



Identity-Centric Access

- Trust is derived from verified user and device identity, **not network location**.
- **No implicit trust** is granted to anything inside the firewall.



Apps on the Internet

All corporate applications are exposed on the public Internet with strong authentication, **eliminating the concept of a privileged intranet**.



Protect Applications

The security model **shifts** from protecting the network perimeter **to** [protecting individual applications and data resources directly](#).



NEW SECTION

Privacy

- Privacy is one of the foundational concerns of digital life.
- As our activities, communications, and habits increasingly move online, [understanding how personal information is collected, shared, and exploited becomes essential for every cybersecurity professional.](#)

What is Privacy?

- **Privacy** is a multifaceted concept at the intersection of law, ethics, and technology.
- At its core, it is about **control over personal information** and **freedom from unwanted intrusion**.

Informational Control

A person's right or expectation to control the disclosure of personal information — including activity metadata such as who you communicate with and when.

"The Right to Be Let Alone"

- Justice Louis Brandeis's foundational definition, still cited today.
- Privacy enables autonomy, free speech, free association, and freedom from constant surveillance.

Historical Context

Privacy violations have real consequences:

- The FBI's surveillance and blackmail of **Martin Luther King Jr.** and McCarthyism's witch-hunts for communists illustrate how privacy erosion can be weaponized against individuals.

The Incredible Story Of How Target Exposed A Teen Girl's Pregnancy



GUS LUBIN
FEB. 16, 2012, 10:27 AM

Target broke through to a new level of customer tracking with the help of statistical genius Andrew Pole, according to a [New York Times Magazine cover story by Charles Duhigg](#).

Pole identified 25 products that when purchased together indicate a woman is likely pregnant. The value of this information was that Target could send coupons to the pregnant woman at an expensive and habit-forming period of her life.

Plugged into Target's customer tracking technology, Pole's formula was a beast. Once it even exposed a teen girl's pregnancy:



Direct Sharing: The Target Case

- One of the most striking examples of privacy risk from **direct data sharing** is the Target pregnancy prediction story.
- Target's statistician [Andrew Pole identified 25 products](#) that, *when purchased together*, **strongly indicate a customer is pregnant**.
- **Target used this to send targeted coupons** — and famously revealed a teenager's pregnancy to her family before she had told them.
- This case illustrates how seemingly innocuous purchasing data can be combined to reveal deeply personal information.

- Amazon's recommendation engine is another example of how purchase and browsing data can be aggregated to infer sensitive personal information.
- *"Customers Who Bought This Also Bought"* reveals behavioral patterns that users may not intend to disclose — including health conditions, lifestyle choices, and family circumstances.

ONLY Brand That Can Tell You
6 DAYS SOONER Than Your Missed Period
Improved Technology

1 FIRST RESPONSE PREGNANCY
EARLY RESULT Pregnancy Test
First to Detect™ Technology

OVER 99% ACCURATE
From the day of your expected period

3 TESTS
EASY ONCE IN THE PM

Roll over image to zoom in

First Response Early Result Pregnancy Test, 3 tests, Packaging May Vary
by First Response
★★★★☆ 486 customer reviews | 17 answered questions
#1 Best Seller in Pregnancy Tests

amazon 47 Amazon Students rated this highly
★★★★☆

List Price: \$49.57
Price: **\$12.98** Prime & Free Returns. Details
You Save: \$6.59 (34%)

Note: Available at a lower price from other sellers, potentially without free Prime shipping.

In Stock.
Ships from and sold by Amazon.com. Gift-wrap available.

Want it Tuesday, March 24? Order within **29 hrs 56 mins** and choose **One-Day Shipping** at checkout. Details
Package Quantity: 1

1	2	3
\$12.98 Prime	\$41.00 Prime	\$57.99

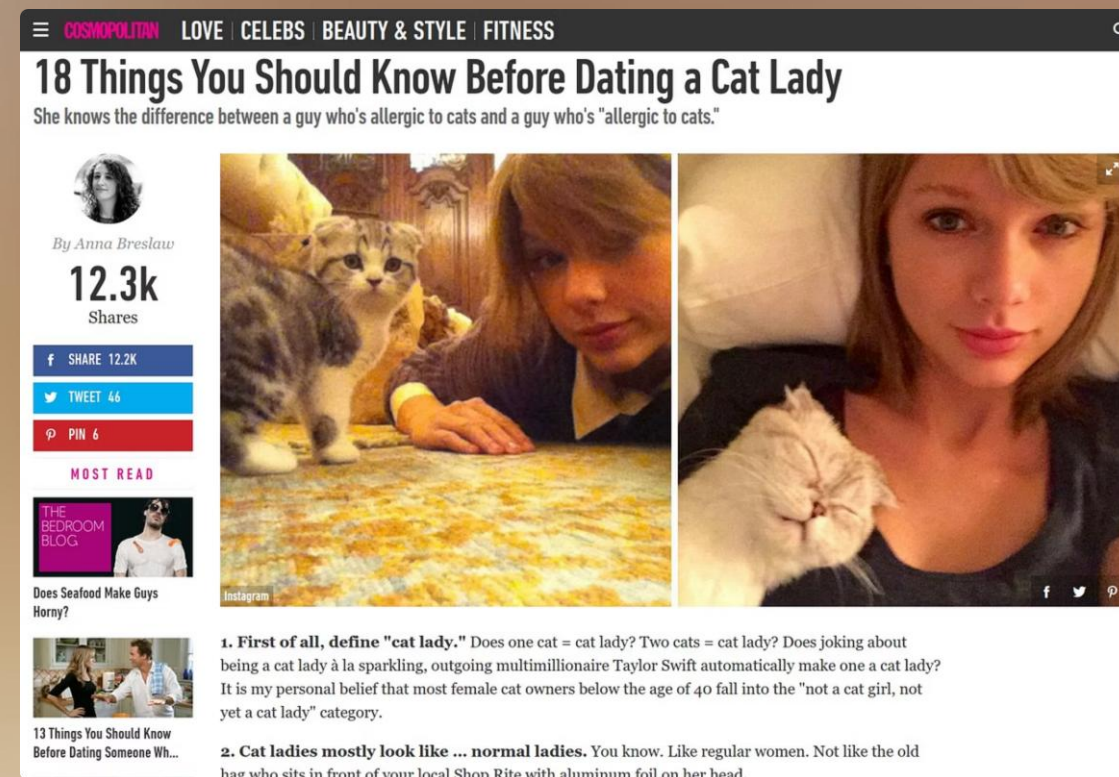
Customers Who Bought This Item Also Bought

Page 6 of 14 | Start over

- Vitafusion Prenatal DHA and Folic Acid Gummy Vitamins, 180 Count
★★★★☆ 140
\$20.25 Prime
- One A Day Women's Prenatal One Pill, 30 Count
★★★★☆ 18
\$13.48 Prime
- Mayo Clinic Guide to a Healthy Pregnancy:... the pregnancy experts...
★★★★☆ 804
#1 Best Seller in Motherhood
- Summer's Eve Cleansing Wash, Morning Paradise, 15 Ounce
★★★★☆ 44
\$3.99
- Nexcare 524560 Basal Digital Thermometer
★★★★☆ 19
\$14.06 Prime
- Nature Made Prenatal Multi Vitamin Value Size, Tablets, 250-Count
★★★★☆ 213
\$16.79 Prime
- Trojan Condom Pleasure Pack Lubricated, 40 Count
★★★★☆ 126
\$18.12 Prime

Third-Party Tracking: A Real-World Example

- Third-party trackers follow users silently *across completely unrelated websites*.
- A user visiting a *Cosmopolitan* article about dating may be *simultaneously tracked* by *ad networks*, *analytics providers*, and *social media plugins* — *none of which are visible to the user*.
- The aggregation of these cross-site observations *builds remarkably detailed behavioral profiles* without the user's awareness or meaningful consent.



Third-Party Cookies: The Mechanism

- When a browser loads a webpage, it often **requests** resources — images, scripts, iframes — from **third-party domains**.
- The browser **automatically sends cookies** associated with those third-party domains in each such request.
- **This allows the third party to observe** which sites the user visits, building a cross-site profile keyed to the cookie ID.

How It Works

- Site A (e.g., CNN) embeds a **DoubleClick** ad.
- The browser sends: **Cookie: ID=784c39** and **Referer: cnn.com/** to **DoubleClick** — silently linking your identity to your browsing context.

The Logos Involved



Third-Party Web Tracking: Cookies and Code

- When a user visits CNN, the browser makes a primary request and also fetches third-party resources like **facebook-like.js**.
- This secondary request **carries the user's Facebook cookie** and the **Referer header revealing the originating page**.
- **Facebook** — or any other embedded third party — **can thus link your cookie ID to your browsing history across all sites where their code is embedded**.

HTTP Exchange Example

GET / HTTP/3 → CNN

GET /facebook-like.js HTTP/3 → Facebook

Cookie: User=Deepak, Referer: **cnn.com**

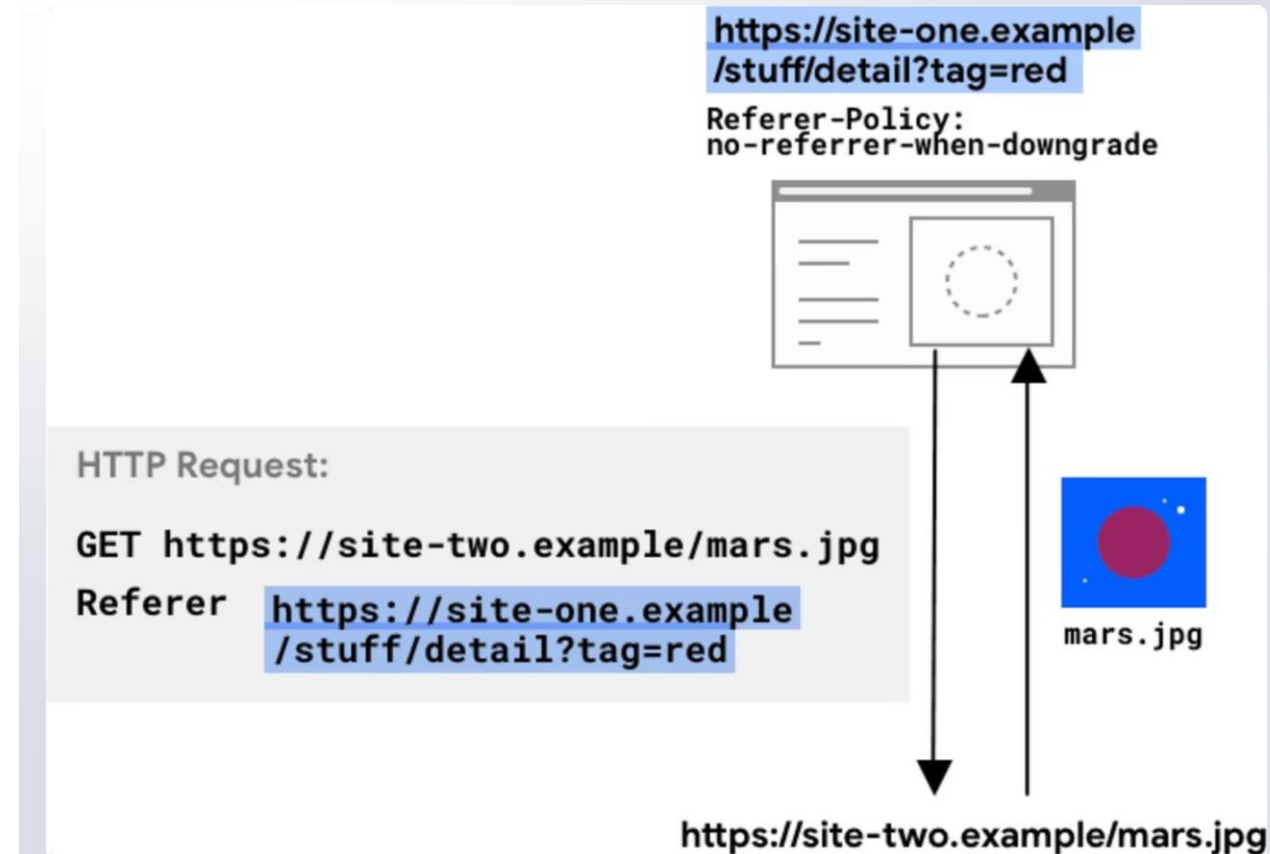
With this request, **companies can link your cookie to your browsing data** via Referer header, Host headers, Origin header, or JavaScript execution.

The screenshot shows the CNN website's homepage. At the top, there's a Squarespace advertisement. Below it, the CNN logo and navigation links (US, World, Politics, Business, Opinion, Health, Entertainment, Style, Travel, Sports, Videos) are visible. A 'LIVE TV' button and search icon are also present. The main content area features several news stories, including 'Trump escalates January 6 cover-up', 'Astros top Braves 9-5 in World Series Game 5', and 'Southwest launches investigation into pilot reportedly using anti-Biden phrase on flight'. On the right side, a purple overlay titled '64 Trackers' lists various third-party tracking services, including AddThis, Adform, Adobe Audience Manager, Adobe Experience Cloud, Aggregate Knowledge, Amazon Advertising, AppNexus, BidSwitch, BlueKai, Bombora, Bounce Exchange, Chartbeat, Criteo, Datalogix, DoubleClick, Drawbridge, Eyeota, Facebook Connect, FreeWheel, Google Ads Measurement, Google AdSense, Google Dynamic Remarketing, Google SafeFrame, Google Tag Manager, Index Exchange, Integral Ad Science, LiveRamp, Lotame, MediaMath, NetRatings SiteCatalyst, OneTag, OpenX, Optimizely, Outbrain, Outbrain Amplify, PowerLinks, PubMatic, Quantcast, RTB House, Rubicon, Salesforce DMP, ScoreCard Research, Simpli.fi, Smaato, SOASTA mPulse, SpotX, Tapad, and TradeDesk.

Web Tracking: What the Referrer Reveals

- The **Referer header** is **one of the most privacy-sensitive parts** of an HTTP request.
- When a browser navigates from one page to another — or loads a third-party resource — **it typically includes the full URL of the originating page.**
- This can **expose sensitive query parameters, search terms, page paths, and user context** to **third parties** that have no legitimate need for that information.

 **Key question:** What exactly is sent in the Referer header — and who receives it?



Third-Party Tracking in the Wild: CNN Example

- This figure shows a real CNN.com page captured with the **Ghostery** browser extension active.
- The panel on the right reveals **44 third-party trackers** running during a single news-page visit, illustrating how much hidden data collection can occur behind an ordinary browsing session.

📄 **44 trackers on one page** — a single visit to CNN triggered dozens of third-party data collection events.

The visible tracker categories include **advertising networks**, **analytics services**, **social media** platforms, and other data brokers. Although the user is simply reading the news, these embedded services **quietly observe the visit** in parallel, often without any direct interaction from the reader.

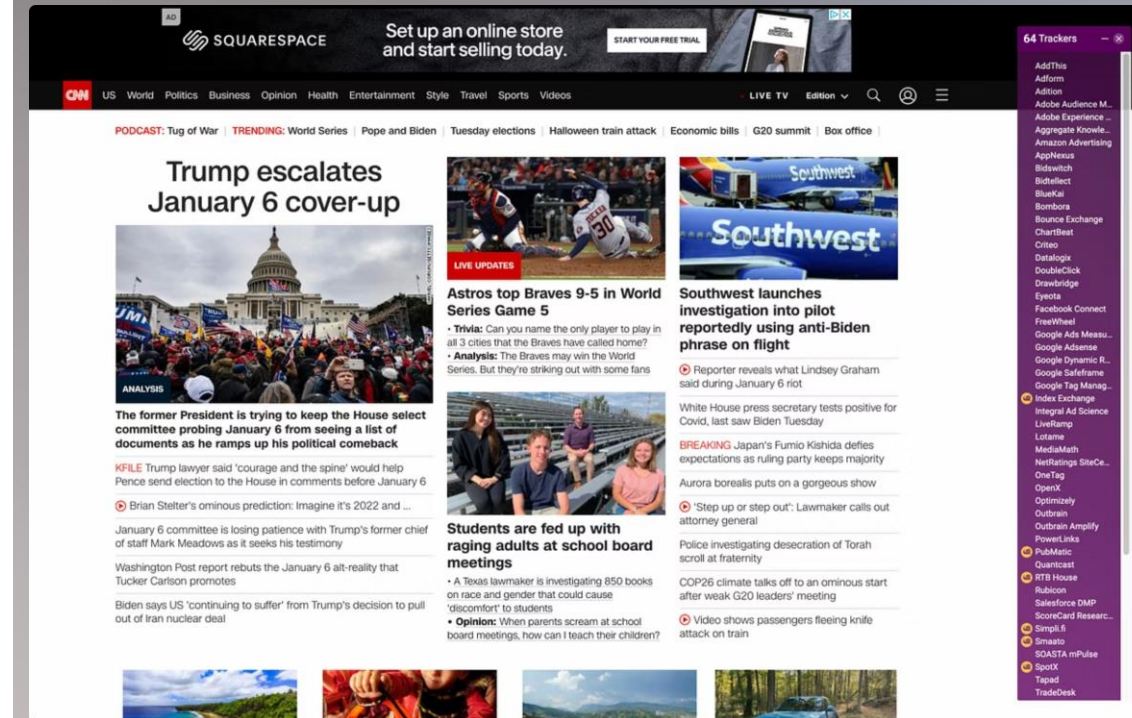
The scale is the key insight: each tracker can **set cookies**, **log the page load**, and **correlate that visit with activity elsewhere on the web**.

- **Advertising trackers** such as DoubleClick and AppNexus help **build behavioral profiles**;
- **Analytics tools** such as Google Analytics and Chartbeat **measure engagement**;
- **Social trackers** such as Facebook Pixel can **link browsing behavior to social identity**.

The **privacy implication** is **straightforward** but significant.

- The user came to read news yet simultaneously shared their visit with dozens of companies they never knowingly engaged with.
- **This is third-party tracking in action**: a distributed ecosystem of surveillance, attribution, and profiling operating inside a single page load.

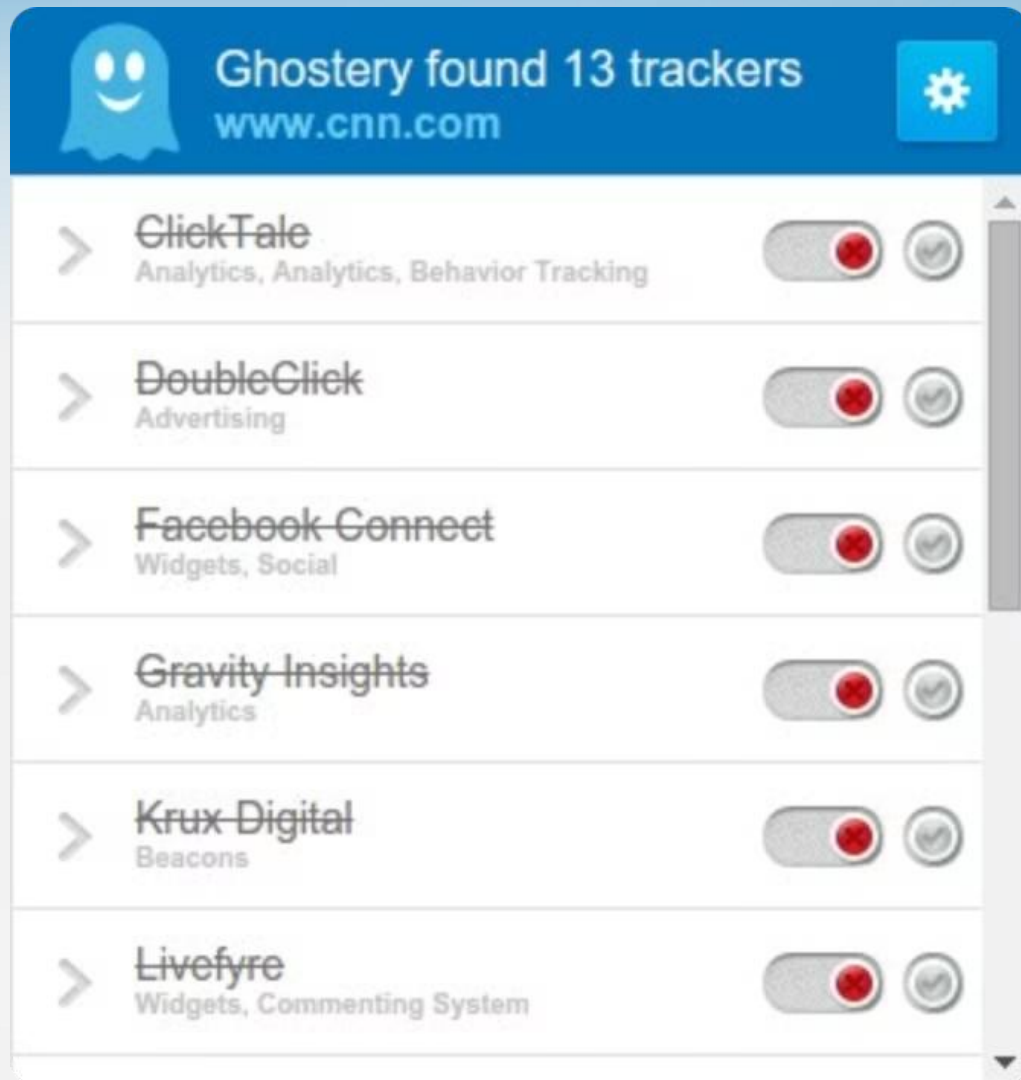
Importantly, each of these 44 tracker requests also carries the **Referer** header. **That means every tracker learns exactly which CNN article the user is reading**, adding page-level context to the broader collection of browsing metadata.



Third-Party Cookies: The Scale of the Problem

- The key insight is that third-party advertising and analytics companies — Facebook, DoubleClick (Google), and others — observe **far more about users than the websites those users actually visit**.
- Because these companies embed tracking pixels, scripts, and iframes across millions of websites, **they accumulate cross-site behavioral profiles of extraordinary depth and breadth**.
- *A single user visiting 20 different sites in a day may be tracked across all 20 by a single ad network.*

Domain	Top 1M	Domain	Top 1M
google-analytics.com	67.8%	ajax.googleapis.com	23.1%
gstatic.com	50.1%	googlesyndication.com	19.6%
fonts.googleapis.com	42.8%	googleadservices.com	14.1%
doubleclick.net	40.5%	twitter.com	12.8%
facebook.com	33.7%	fbcdn.net	10.7%
google.com	33.2%	adnxs.com	10.5%
facebook.net	27.4%		

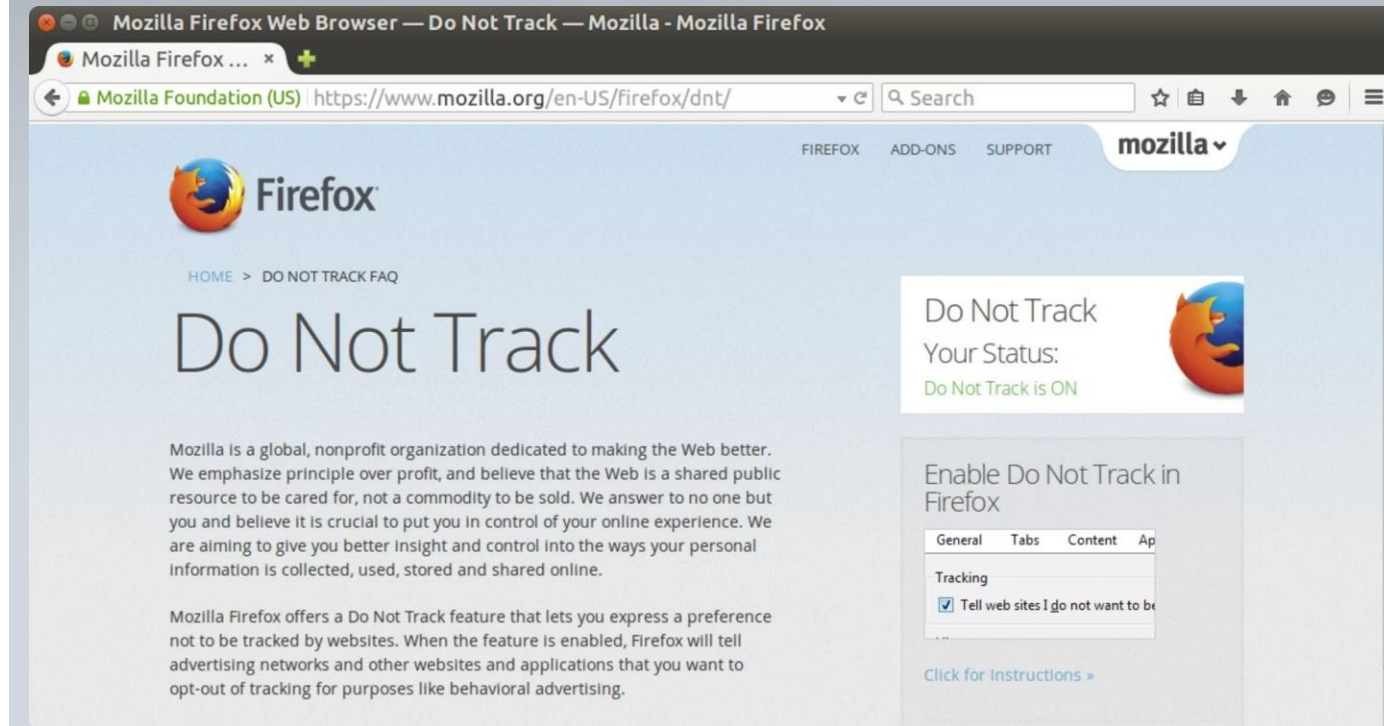


Ghostery: Visualizing the Trackers

- Ghostery is a **browser extension** that **detects** and optionally **blocks** third-party trackers on web pages, giving users visibility into the hidden tracking ecosystem that operates beneath every webpage.
- When installed, **it reveals the often-shocking number** of analytics, advertising, and social media trackers present on even a single news article or retail page — sometimes numbering in the dozens.

DNT: Do Not Track

- **Do Not Track (DNT)** was **a proposed browser standard** that would signal a user's preference not to be tracked to websites and third parties.
- While browsers implemented the header, **compliance was entirely voluntary** — and **the advertising industry largely ignored it**.
- **DNT was ultimately abandoned** as a meaningful standard, **illustrating the limits of voluntary privacy frameworks** and the need for regulatory or technical enforcement mechanisms.



2024 — The End of Third-Party Cookies?

- The browser ecosystem has been **converging toward blocking third-party cookies**, though at different paces and with different approaches.
- Chrome's delayed deprecation reflects the enormous economic stakes for Google's advertising business.

Firefox

- **Drops third-party cookies** from known trackers.
- **Uses a separate cookie jar per site** to prevent cross-site tracking — even if cookies aren't blocked outright.

Safari

- **Blocks all third-party cookies by default** via Intelligent Tracking Prevention (ITP).
- One of the earliest and most aggressive browser stances.

Chrome

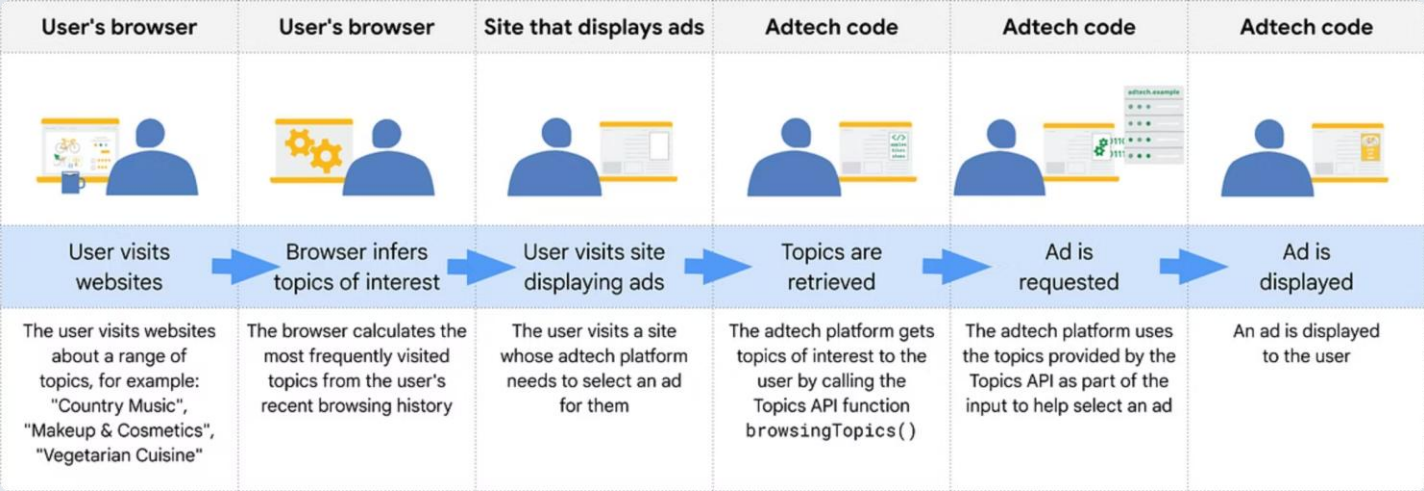
- ***Announced deprecation of third-party cookies by end of 2024*** — the most impactful change given Chrome's ~65% market share.
- **Repeatedly delayed** due to industry pressure.

IE / Edge

- IE **blocked some** third-party cookies via a **baked-in blacklist**.
- Edge **does not block third-party cookies by default** — lagging behind other browsers.

Google Topics: The Replacement API

- As Google phases out third-party cookies, it proposed the **Topics API** as *a privacy-preserving alternative for interest-based advertising*.
- Rather than sharing raw browsing history across sites, the browser itself categorizes the user's interests locally and *shares only a few broad topic labels with advertisers*.
- Topics** are drawn from *a hierarchical taxonomy* (e.g., /Arts & Entertainment/Music & Audio/Soul & R&B).
- For each ad request, the browser returns *at most three topics* — chosen randomly from the user's top five topics across the past three weeks (epochs) — *with a 5% chance of substituting a random topic to provide plausible deniability*.



Browser Fingerprinting

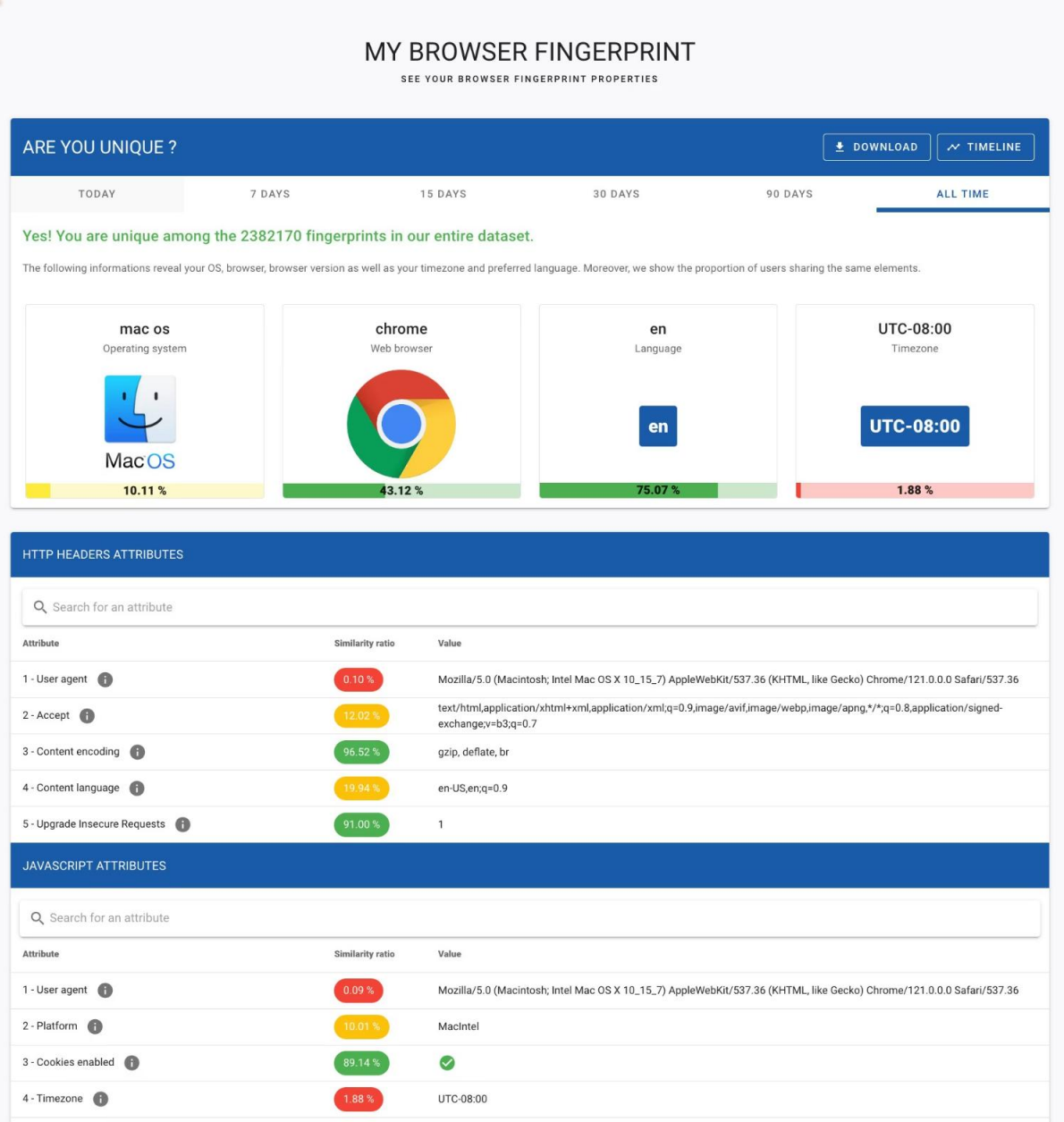
- Even without cookies, websites can identify and track users through **browser fingerprinting**
 - a technique that **collects dozens of attributes** about your browser and device configuration and combines them into **a near-unique identifier**.
- Since most fingerprinting relies on JavaScript, blocking third-party scripts is the primary defense.

What Gets Fingerprinted?

- Browser type, version, and installed plugins
- Screen resolution and color depth
- Installed fonts (via canvas rendering)
- Time zone and language settings
- Hardware concurrency and memory

Test your own fingerprint uniqueness at amiunique.org

```
{
  "user-agent": "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:93.0) Gecko/20100101 Firefox/93.0",
  "accept": "text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8",
  "accept-encoding": "gzip, deflate, br",
  "accept-language": "en-US,en;q=0.5",
  "upgrade-insecure-requests": "1",
  "referrer": "https://amiunique.org/",
  "userAgent-js": "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:93.0) Gecko/20100101 Firefox/93.0",
  "platform": "MacIntel",
  "cookies": "yes",
  "timezone": 420,
  "languages-js": "en-US,en",
  "ad": "no",
  "doNotTrack": "NC",
  "navigator_properties": [
    "vibrate",
    "javaEnabled",
    "getGamepads",
    "getVRDisplays",
    "mozGetUserMedia",
    "sendBeacon",
    "requestMediaKeySystemAccess",
    "registerProtocolHandler",
    "taintEnabled",
    "permissions"
  ]
}
```



		pdf-viewer.
20 - Screen width	4.25 %	2560
21 - Screen height	4.58 %	1440
22 - Screen depth	3.64 %	30
23 - Screen available top	3.32 %	25
24 - Screen available Left	83.26 %	0
25 - Screen available Height	0.01 %	1346
26 - Screen available width	4.07 %	2560
27 - Permissions	6.24 %	accelerometer : granted accessibility : Not supported ambient-light-sensor : Not supported camera : prompt clipboard-read : prompt clipboard-write : granted geolocation : prompt background-sync : granted magnetometer : granted microphone : prompt midi : granted notifications : prompt payment-handler : granted persistent-storage : prompt push : Not supported
28 - WebGL Vendor	1.83 %	Google Inc. (Apple)
29 - WebGL Renderer	0.01 %	ANGLE (Apple, ANGLE Metal Renderer: Apple M2 Max, Unspecified Version)
30 - WebGL Data	0.13 %	
31 - WebGL Parameters	0.03 %	35 different extensions 25 different general parameters analyzed 36 different shaders precisions analyzed

Browser fingerprinting tools compile and cross-reference a wide range of browser and device attributes to generate a stable unique identifier — even across different browsing sessions and without storing any local data.

Incognito Mode: Privacy Through Cognitive Browsing

What it is

A private browsing session that changes **local browser behavior** by **avoiding the persistent storage** of session artifacts on the device.

What it protects

- No browsing history is saved locally
- Cookies are not retained after the session ends
- Form entries and search history are not stored on the device
- Downloaded files and bookmarks remain, but **transient session data** is cleared

What it does not protect

- Incognito mode is **not anonymity**.
- Your ISP, employer, network administrator, and the websites you visit **can still observe your activity and network requests**.

Psychological effect

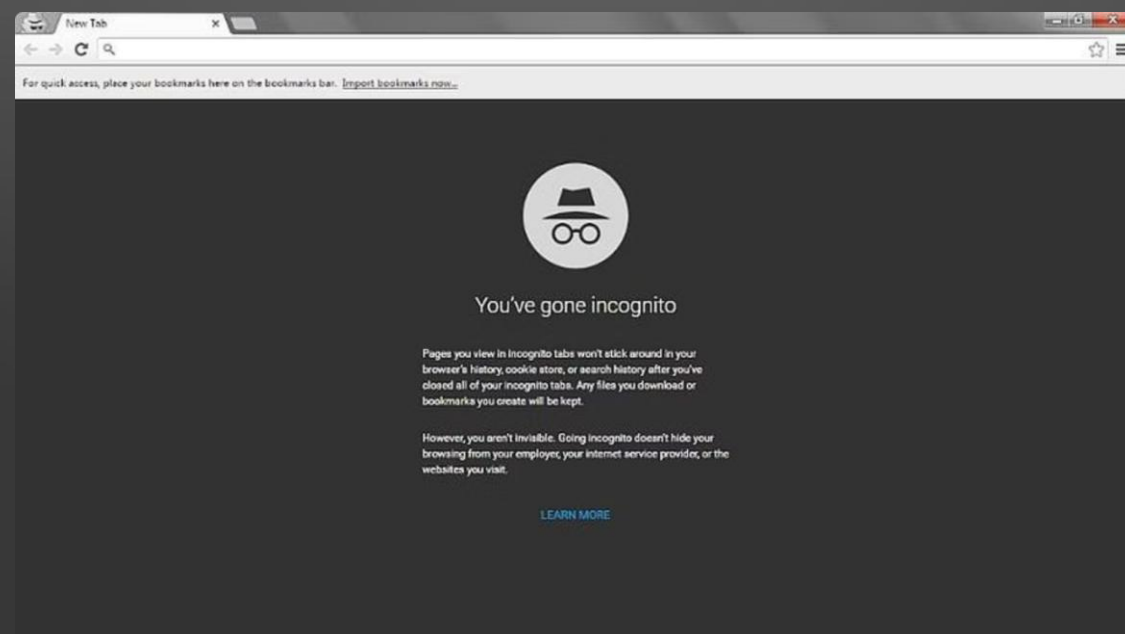
- Users **often overestimate** the privacy it provides.
- This *privacy paradox* **reflects a mismatch** between *perceived protection* and *actual visibility* at the network and service layers.

How it compares

- VPNs can **mask traffic** from local observers, while **Tor** is designed to provide stronger anonymity by **routing traffic through multiple relays**.
- Incognito mode **does neither**; it **only limits what the browser stores on the device**.

Common use cases

- Using shared or public computers
- Reducing local tracking on a personal device
- Testing websites without cached data or existing cookies



Bankruptcy: Legal Framework and Process

- **Bankruptcy** is a legal process that helps individuals who can no longer pay their debts obtain a fresh start through liquidation or a structured repayment plan.
- It also provides a mechanism for financially troubled businesses to reorganize or wind down under court supervision.

What bankruptcy does

- *Filing bankruptcy can either eliminate certain debts or create a court-approved plan to repay them over time.*
- A bankruptcy case is normally filed with the bankruptcy court.

Key resources

- Bankruptcy Forms
- Chapter 7 Fee Waiver Procedures
- Protection of Tax Information Guidance
- Pending Bankruptcy Forms

Who may file

A petition may be filed by an individual, by spouses together, or by a corporation or other entity, depending on the applicable chapter and eligibility rules.

Security and privacy significance

- **Bankruptcy filings are public court records.**
- They **can expose sensitive financial details** such as assets, debts, creditors, and personal information, making them **highly relevant to privacy and information-security discussions** in the digital age.

Types under the U.S. Bankruptcy Code

- Chapter 7: individuals may file to liquidate assets and discharge eligible debts
- Chapter 13: individuals may file to reorganize debt through a repayment plan
- Chapter 9: municipalities such as cities, towns, villages, and taxing districts may file to reorganize
- Chapter 11: businesses may file to reorganize
- Chapter 7: businesses may also file to liquidate

The screenshot shows the official website of the United States Courts, specifically the Bankruptcy section. The header includes the U.S. Courts logo and navigation links for Email Updates, Federal Court Finder, Careers, News, and a search bar. Below the header, there are tabs for About Federal Courts, Judges & Judgeships, Services & Forms (which is selected), Court Records, Statistics & Reports, and Rules & Policies. The main content area is titled 'Bankruptcy' and features a sidebar with links to Bankruptcy Basics, Filing Without an Attorney, Credit Counseling and Debtor Education, Trustees and Administrators, and Approved Bankruptcy Notice Providers. The main text explains that bankruptcy helps people who can no longer pay their debts get a fresh start by liquidating assets or creating a repayment plan. It also mentions that bankruptcy laws protect financially troubled businesses. To the right, there are 'Related Links' such as Bankruptcy Fees, Bankruptcy Forms, Chapter 7 Fee Waiver Procedures & Resources, Protection of Tax Information Guidance, Pending Bankruptcy Forms, and Permitted Changes to Official Bankruptcy Forms. At the bottom right, there is a 'Federal Court Finder' section with a 'Location' button and a search bar for 'Address, city, state, or ZIP'.

Privacy Enhancing Technologies (PETs)

- **Privacy Enhancing Technologies** are *tools and protocols* specifically designed to **protect personal data and limit information disclosure**.
- The most impactful and broadly deployed **PET** is **TLS (Transport Layer Security)** — it comes built into every web browser, requires no user configuration, and protects the *content* of communications from passive eavesdroppers and active man-in-the-middle attacks.



TLS / HTTPS

- **Protects** content of web and email communications.
- **Transparent** to users.
- **Defends** against passive sniffing and active MITM attacks from ISPs, coffee shops, and landlords.



Encrypted Email

- TLS also **secures** email in transit via STARTTLS.
- **Combined** with end-to-end encryption (e.g., PGP/S-MIME), it provides *confidentiality for message contents*.



Beyond Confidentiality

- **Confidentiality tools** also provide some privacy benefit — **preventing network observers** (ISPs, shared networks) from learning sensitive details about your activities.

Encouraging HTTPS Adoption

- HTTPS adoption required active ecosystem pressure beyond technical availability.
- A combination of incentives and penalties from major browser and platform vendors has driven widespread HTTPS deployment over the past decade.

1 — 2014

Google begins using HTTPS as a **page rank signal**, incentivizing webmasters to deploy TLS for SEO benefits.

2 — Early 2018

Mozilla announces that all **new browser features** (e.g., service workers, geolocation) will require HTTPS — blocking HTTP sites from modern capabilities.

3 — Late 2018

Chrome introduces new **security indicators**: HTTP pages are labeled "Not Secure," creating visible user-facing pressure to migrate.

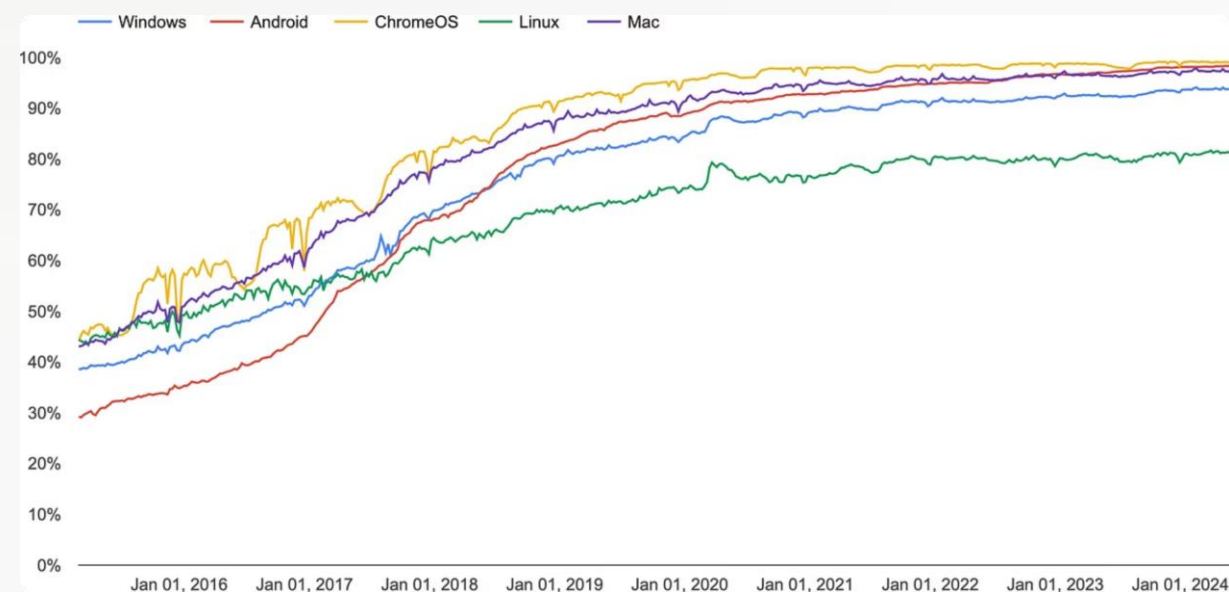
📘 example.com

📘 Not secure | example.com

Chrome Page Loads over HTTPS

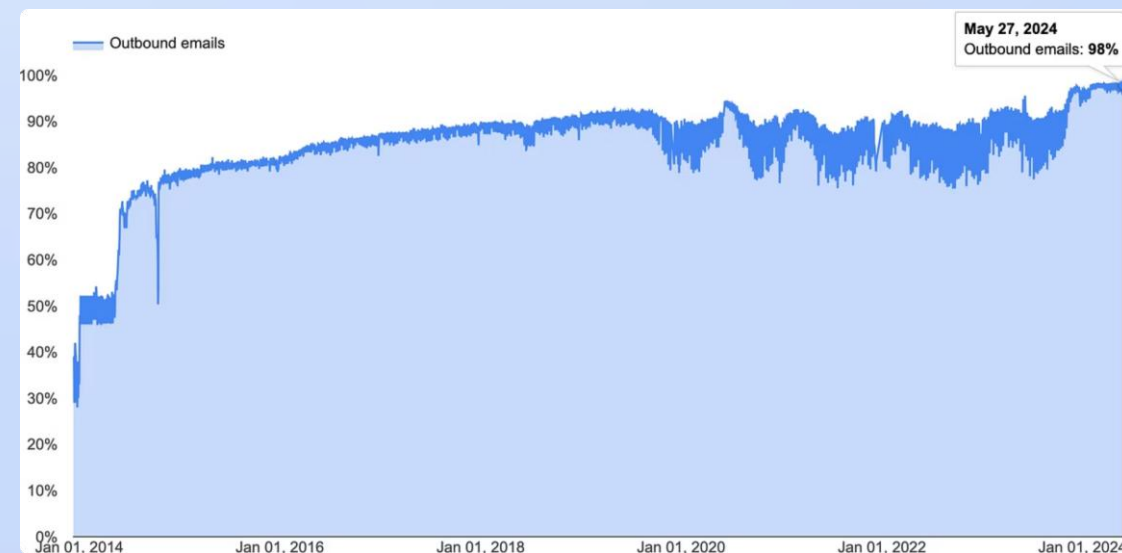
- **Google's Transparency Report** tracks *the percentage of Chrome browser page loads served over HTTPS across different platforms and countries.*
- **The trend has been consistently upward** — demonstrating the real-world impact of ecosystem-level incentives.
- The data reveals that **the combination of Let's Encrypt (free TLS certificates), browser pressure, and SEO incentives** has been remarkably effective at shifting the web toward encrypted-by-default traffic.

Source: Google Transparency Report



STARTTLS as Seen by Gmail

- **STARTTLS** is an opportunistic encryption mechanism for email protocols (SMTP, IMAP, POP3) that upgrades a plaintext connection to TLS when both parties support it.
- Gmail's transparency data shows the dramatic increase in email encrypted in transit over time — **highlighting** both progress and the persistent gap where **some email providers still don't support TLS**, leaving messages exposed to interception at the network level.



Protecting Metadata

📄 **Key Limitation:** TLS protects the *contents* of communication — but not the metadata surrounding it.

Metadata — who is communicating with whom, when, and how frequently — can be as revealing as content itself. Governments and adversaries with network-level visibility can observe communication patterns without ever breaking encryption.

Website Visits

Even over HTTPS, an ISP or government **can see that you visited *hrw.org*** (Human Rights Watch) — **the IP address and DNS query are visible.**

Communication Patterns

Who sends messages to whom, and at what times, *reveals relationships and associations* — potentially dangerous in authoritarian contexts.

Existence of Communication

In some contexts, simply ***sending an encrypted message*** is **enough to attract attention** — the existence of the message is itself metadata.

What is Anonymity?

- **Anonymity** (from Greek: "without name") is the property of being **not identifiable** within a set of subjects.
- It is a **stronger privacy property than confidentiality** — it is not just about hiding the content of communication, but about hiding the relationship between an action and its actor.

Unlinkability

- An action cannot be linked to its actor.
- For example, a sender and their email address should be no more related after an adversary's observations than they were before.
- Covers the question: *who talks to whom?*

Unobservability

An adversary cannot determine whether a specific person is using a particular system or protocol at all
— not just who they're communicating with, but whether they're communicating.

Why Anonymity Matters

Anonymity is not just for criminals — it is a critical tool for journalists, activists, medical patients, and ordinary citizens navigating an increasingly surveilled digital world.



Protecting Privacy

Avoiding tracking by advertising companies or accessing sensitive content — such as medical condition information or bankruptcy advice — **without creating a permanent record of that access.**



Protection from Prosecution

- **Not every country** guarantees free speech or freedom of assembly.
- **Anonymity can protect** activists, journalists, and dissidents from government reprisal for legally or politically sensitive communications.



Preventing Chilling Effects

- **Surveillance** has a **chilling effect** on speech and behavior.
- People **are more willing** to voice unpopular or controversial opinions when they believe they are not being observed and recorded.

Anonymity is Hard

- Achieving meaningful anonymity on the Internet is **technically and operationally challenging**.
- The Internet's fundamental design works against it — every packet carries identifying information, and surveillance infrastructure is extensive.

IP Addresses in Every Packet

- Source and destination IP addresses are **embedded in every packet header**.
- Any router along the path — including your ISP — can see who you're communicating with.

ISP Records

- ISPs log communication records which can be **subpoenaed by law enforcement**.
- In many jurisdictions, these records must be retained for months or years.

Wireless Interception

Wireless traffic can be trivially **intercepted by anyone within radio range** — making coffee shop and airport networks a significant surveillance risk.

Nation-State Surveillance

Tier 1 ASes and Internet Exchange Points (IXPs) are known to be **compromised by intelligence agencies** — NSA, GCHQ, and the broader "Five Eyes" alliance.

Anonymity Requires Help

"Anonymity is difficult if not impossible to achieve on your own. You generally need help."

- **The fundamental challenge:** any time you send a packet, your IP address identifies you.
- The state-of-the-art technique for circumventing this is conceptually simple — **ask someone else to send it for you.**
 - This is the basis for [proxy-based anonymity systems](#), including VPNs and, more robustly, Tor.
- **The key question becomes:** *who do you trust to send it on your behalf?*



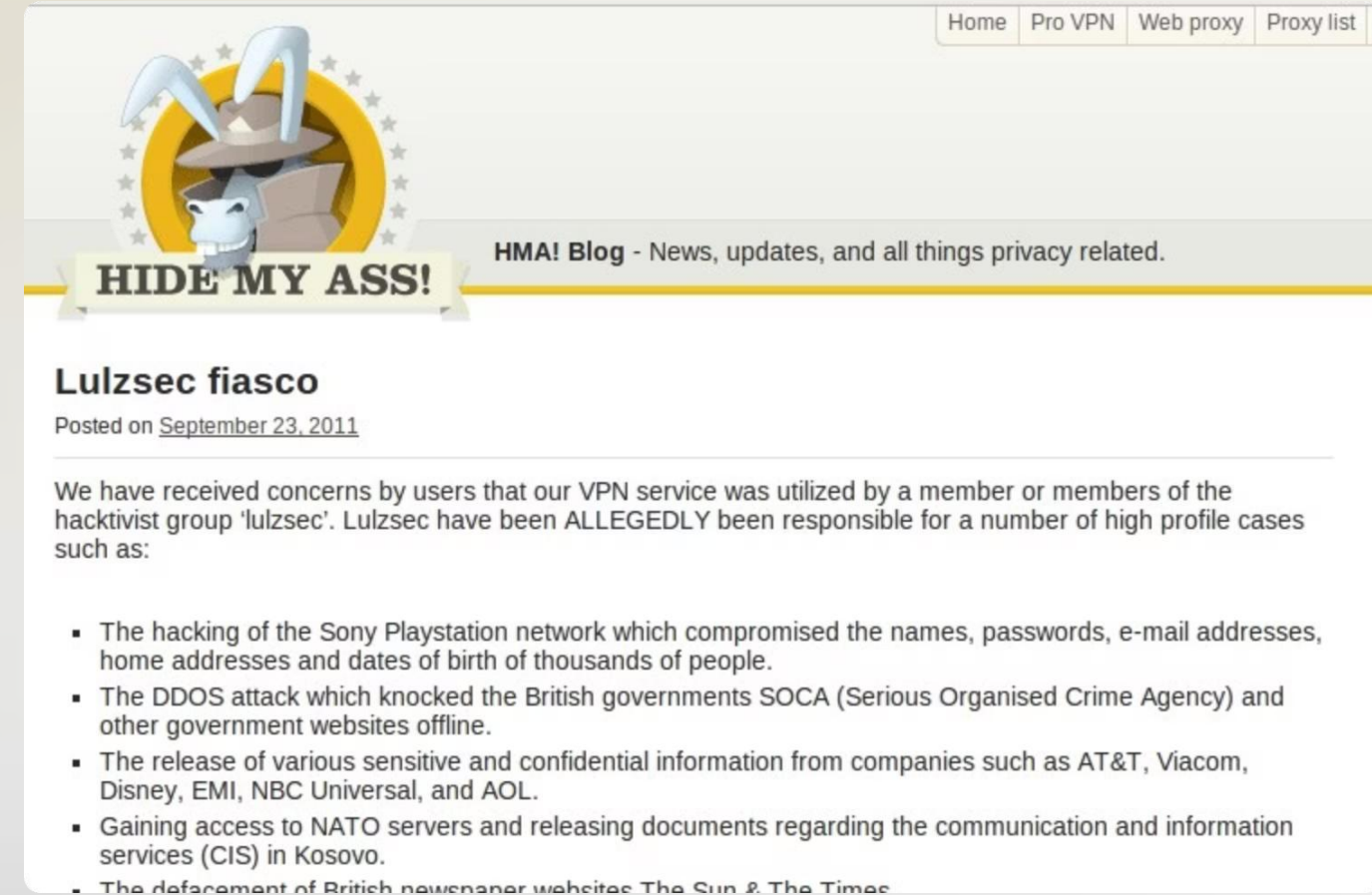


Naive Approach: VPNs for Anonymity

- The **most common naive approach** to online anonymity is using **a commercial VPN**.
- **The idea is straightforward**: instead of connecting directly to a destination, you **route your traffic** through a VPN server.
- The destination **sees** the VPN server's IP address — not yours.
- But this approach simply **shifts trust rather than eliminating it**.
- **You're now trusting the VPN provider with everything you previously trusted your ISP with.**

The VPN Trust Problem

- **Commercial VPN providers** market themselves as privacy tools, but they **operate centralized services that become a single point of surveillance**.
- **Marketing claims of "no logs"** are difficult to verify and frequently contradicted when law enforcement comes knocking.
- A VPN provider that *can* log your traffic will likely be compelled to do so under legal pressure.



The screenshot shows the HMA! Blog website. At the top right, there are navigation links: Home, Pro VPN, Web proxy, and Proxy list. The main header features a cartoon rabbit wearing a brown hat and a yellow banner that reads "HIDE MY ASS!". To the right of the banner, it says "HMA! Blog - News, updates, and all things privacy related." Below the header, the article title "Lulzsec fiasco" is displayed, followed by the date "Posted on September 23, 2011". The article text begins with "We have received concerns by users that our VPN service was utilized by a member or members of the hacktivist group 'lulzsec'. Lulzsec have been ALLEGEDLY been responsible for a number of high profile cases such as:" and is followed by a bulleted list of incidents.

Home Pro VPN Web proxy Proxy list

HIDE MY ASS! HMA! Blog - News, updates, and all things privacy related.

Lulzsec fiasco

Posted on September 23, 2011

We have received concerns by users that our VPN service was utilized by a member or members of the hacktivist group 'lulzsec'. Lulzsec have been ALLEGEDLY been responsible for a number of high profile cases such as:

- The hacking of the Sony Playstation network which compromised the names, passwords, e-mail addresses, home addresses and dates of birth of thousands of people.
- The DDOS attack which knocked the British governments SOCA (Serious Organised Crime Agency) and other government websites offline.
- The release of various sensitive and confidential information from companies such as AT&T, Viacom, Disney, EMI, NBC Universal, and AOL.
- Gaining access to NATO servers and releasing documents regarding the communication and information services (CIS) in Kosovo.
- The defacement of British newspaper websites The Sun & The Times

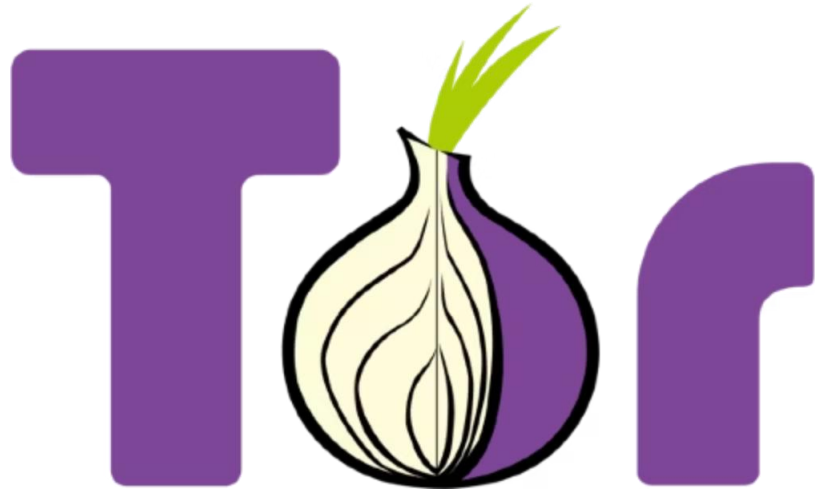
VPNs and Law Enforcement

This real-world case illustrates **the fundamental weakness of VPN-based anonymity**:

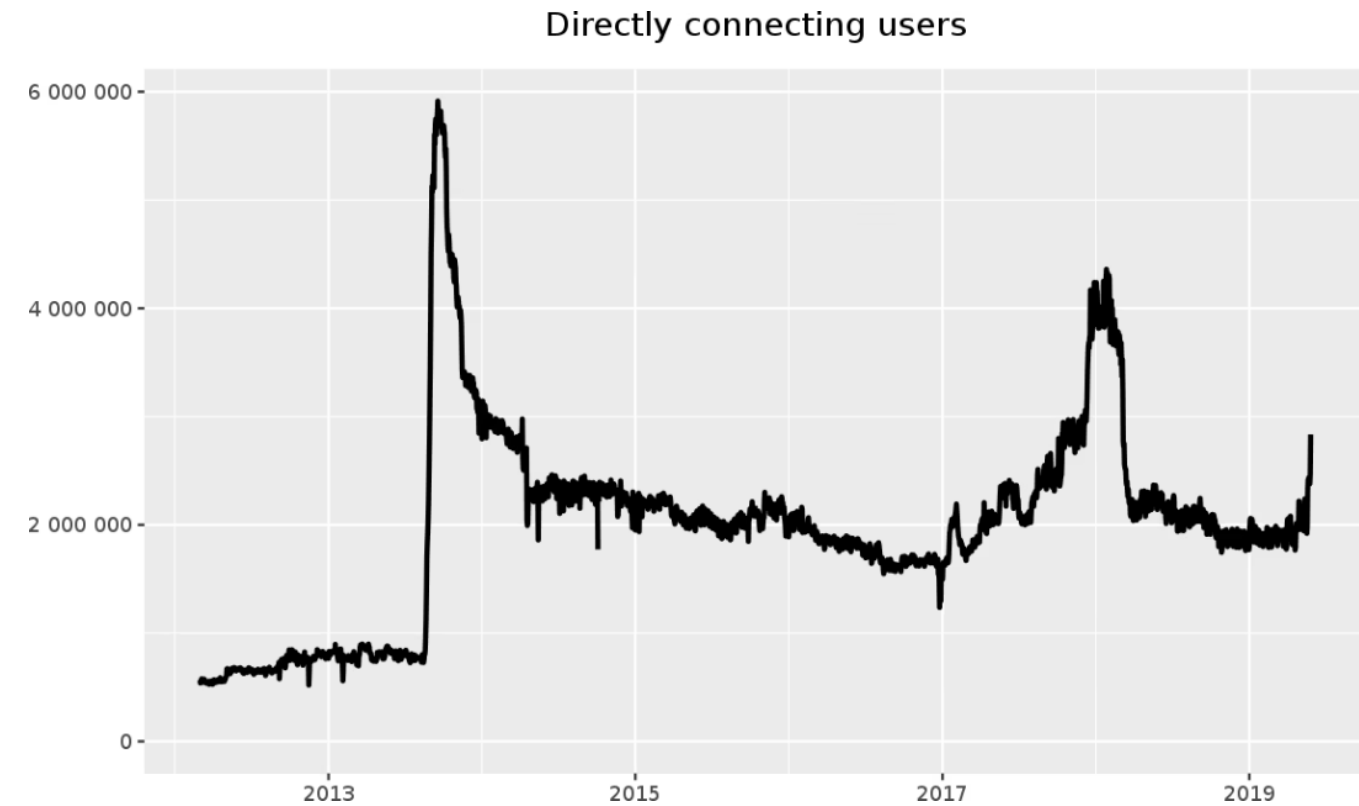
- **VPN providers** are legitimate businesses **subject to legal jurisdiction**.
- When they receive a court order, they comply — and **their logs become evidence**.
- The **"no-logs" marketing** claim is only as strong as the provider's technical architecture and legal exposure.

"...received a **court order** asking for information relating to an account associated with some or all of the above cases. As stated in our terms of service and **privacy policy**, our service is not to be used for illegal activity, and as a legitimate company ***we will cooperate with law enforcement if we receive a court order.***"

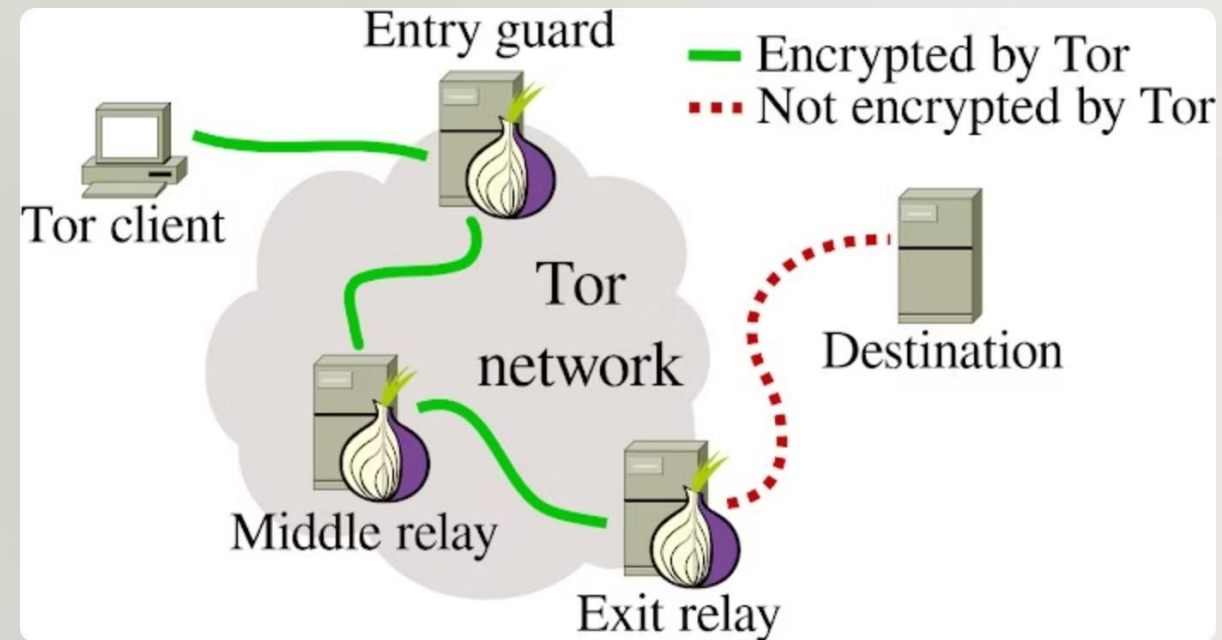
Tor: A Better Anonymity Solution



- **Tor (The Onion Router)** is the most successful privacy-enhancing technology **operating at the transport layer**.
- With **millions of active users**, it addresses the fundamental limitation of VPNs by **distributing trust across multiple nodes**.
- A normal TCP connection reveals your IP address to every party along the path.
- Tor allows TCP connections to be established **without revealing the client's IP address** to the destination — or to any single intermediary.



Tor: The Onion Router



- Tor achieves anonymity by tunneling traffic through a **circuit of three volunteer-operated "onion routers"** (relays) using **layered public key cryptography**.
- **Each relay decrypts** only one layer of encryption — *like peeling an onion* — exposing only the next hop in the circuit.
- **No single relay** ever knows **both the origin and the destination** of the traffic.
- The client negotiates separate encryption keys with each relay.
- The message is encrypted in three layers before being sent. Each relay peels one layer, revealing only the next relay's address — never the source or final destination simultaneously.

Who Knows What in Tor?

- The distributed nature of Tor ensures that no single node has complete information about a communication.
- This is the key architectural advantage over a VPN, where the single provider sees everything.

Entry Node

Knows that **Alice is using Tor** and the identity of the middle node — but has **no knowledge of the destination**.

Middle Node

Knows the entry node and the exit node — but **cannot identify** Alice or the final destination website.

Exit Node

Knows some Tor user is connecting to the destination — but **does not know which user** originated the traffic.

Destination

Knows a Tor user is connecting via the exit node — but has **no knowledge of Alice's identity**.

Note: use HTTPS, as Tor does not encrypt the exit-to-destination segment!

Does Tor Provide Anonymity?

Tor **provides anonymity** for TCP connections over the Internet — but with important nuances about **short-term linkability** versus **long-term unlinkability**.

Long-Term Unlinkability

- There is no persistent identifier for a Tor user across sessions.
- If a web server receives a connection from a Tor exit node today and another tomorrow, it **cannot determine** whether those came from the same person.

Short-Term Linkability

Two connections **arriving in quick succession** from the same Tor exit node are **statistically more likely** to come from the same person — **creating a probabilistic short-term linkage that adversaries may exploit through correlation attacks**.

Tor Challenges and Attacks

- While Tor provides strong anonymity against many adversaries, **it is not invulnerable**.
- Understanding its known attack vectors is essential for a realistic security assessment.

Performance Overhead

- Messages traverse multiple hops with encryption/decryption at each.
- **Tor** can be **significantly slower** than direct connections — a real usability barrier.

Coercion of Relay Operators

- **Attack:** Government coerces server operators in one country.
- **Defense:** Use mix servers in different legal jurisdictions, making coordinated coercion harder.

Adversary-Controlled Relays

- **Attack:** Adversary operates a large fraction of all mix servers.
- **Defense:** Tor has ~7,000 onion routers today — a diverse, global pool that resists capture.

Timing / Traffic Analysis

- **Attack:** Adversary observes when Alice sends and when Bob receives — a side-channel attack exploiting timing correlation.
- **Defense:** Pad messages and introduce delays. Tor pads messages **but acknowledges it's insufficient for a fully capable adversary**.

Guard Relays

- A key threat to Tor anonymity is an adversary creating a large number of malicious onion routers and performing **timing observation** at both the entrance and exit of the network to correlate traffic.
- **Tor** mitigates this with the **Guard Relay** mechanism.

What Are Guard Relays?

- A subset of Tor relays designated as **trusted entry points**.
- **They limit the probability** that a malicious actor controls your circuit's entry node by restricting which nodes a client uses for initial connections.

Selection Criteria

Guard relays must demonstrate long and consistent uptimes, high bandwidth, and have been manually vetted and approved by the Tor community.

Rotation Policy

- A Tor client selects **3 guard relays** and uses them exclusively for **3 months**.
- This limits exposure — an adversary who doesn't control your guards can't observe your entry traffic.

Exit Nodes: Volunteering with Risk

- Unlike entry and middle relays, **exit nodes** represent the point where Tor traffic re-enters the public Internet — **and where legal liability concentrates**.
- **Relays** must **self-elect** to become exit nodes, because operating one comes with significant legal and operational risk.

Why Exit Nodes Are Risky

- If a Tor user performs malicious or illegal activity, law enforcement traces the traffic back to the **exit node's IP address** — **not the original user**.
- **Exit node operators** have faced police raids, equipment seizures, and legal proceedings — despite being innocent third parties.

Mitigation Strategies

- **Register** as a Tor exit operator with ISPs and law enforcement proactively
- **Use a dedicated IP address** exclusively for Tor exit traffic
- **Consult** the Electronic Frontier Foundation (EFF) legal guidelines for exit operators
- **Deploy exit policy restrictions** to block high-risk ports

Resources

Prescribed Reading

Course materials and lecture notes for ICT306 Advanced Cybersecurity, Lecture 9 — Privacy, Anonymity, and Censorship. Available on the course portal.

Recommended Reading

Whitman, Michael E., and Herbert J. Mattord. *Principles of Information Security*. Cengage Learning, 2021. — **Module 1, Pages 1–26.**

Online Tools

amiunique.org — Test your browser fingerprint uniqueness. Google Transparency Report — HTTPS adoption trends across Chrome. Tor Project — torproject.org



Key Takeaways

01

VPNs secure traffic — but shift trust

IPSec, WireGuard, and AnyConnect encrypt traffic effectively, but the Zero Trust model challenges the perimeter assumption entirely.

02

Privacy is about more than encryption

TLS protects content but not metadata. Third-party cookies, browser fingerprinting, and behavioral profiling threaten privacy at scale.

03

Anonymity requires distributed trust

VPNs are a naive anonymity tool. Tor's layered routing across multiple independent relays provides meaningful unlinkability — with known trade-offs in performance and attack resistance.